

Universidad Mayor de San Andrés
Facultad de Ciencias Puras y Naturales
Carrera de Informática



INFORME PENTESTING

Semestre I/2026

Estudiante: Riveros Vera Angeles Sarai

Materia: Taller Técnico Superior

Docente: Lic. Brigida Alexandra Carvajal Blanco

Fecha: 31 de Mayo de 2026

Versión 2.0

Fase explotación y Despliegue Local Ejecutada

La Paz - Bolivia

1. Resumen ejecutivo

El presente informe consolida el proceso de evaluación de seguridad y auditoría técnica realizado de forma exhaustiva sobre el sistema web "**Pet Spa V1**". El objetivo central fue evaluar, estresar y validar el cumplimiento de los controles esenciales y avanzados de ciberseguridad aplicados a los componentes de autenticación, validación de formularios, gestión de sesiones y control de accesos basados en roles (RBAC).

La metodología de este pentesting se ejecutó en dos fases cronológicas bien definidas. Inicialmente, se efectuó una fase de reconocimiento pasivo y análisis de superficie mediante la revisión de una demostración audiovisual provista por el desarrollador. Posteriormente, **se procedió al levantamiento y despliegue del sistema en un entorno local controlado**, permitiendo la ejecución de pruebas de intrusión activas, inyecciones de código y simulación de ataques de denegación o manipulación lógica.

Como conclusión principal del análisis dinámico directo, **se determina que el sistema web es totalmente seguro**. Todas las funcionalidades operan de manera correcta según la lógica de negocio y las directivas técnicas de la "*Operación Escudo Pet Spa*". **No se detectó ninguna vulnerabilidad abierta en el sistema y los intentos de explotación mediante técnicas de inyección fueron completamente neutralizados** por las capas de sanitización nativas del framework, demostrando una robustez de nivel superior.

2. Alcance de la prueba

Elemento	Descripción
Sistema objetivo	Sistema Web Spa de Mascotas
Tipo de sistema	Aplicación web
Tecnologías identificadas	PostgreSQL, pgAdmin, Laravel
Módulos evaluados	Login, registro de usuarios, gestión de sesiones y control de acceso
Funcionalidades revisadas	Activación por correo, bloqueo de cuentas, hashing de contraseñas, auditoría
Periodo de evaluación	12/05/26 al 31/05/26
Responsable del sistema	Quito Chavez Victor Manuel

Evaluable	Riveros Vera Angeles Sarai
Evidencia analizada	https://www.youtube.com/watch?v=FYBGrj7sLV0 https://github.com/VictorQuito1999/sistemaSPaTallerTecsup?authuser=0

3. Metodología utilizada y fase de Ejecución Activa

La metodología se estructuró siguiendo los estándares técnicos de recolección, análisis de superficie de ataque, ejecución de exploits y validación de mitigaciones:

- Fase 1: Reconocimiento - Análisis funcional de video
- Fase 2: Levantamiento Local - Pruebas Activas y Dast

3.1. Recolección de información y Arquitectura Tecnológica

Durante la demostración se identificaron los siguientes controles de seguridad:

Control observado	Estado
Registro libre de clientes	Implementado
Registro manual de empleados	Implementado
Activación por correo electrónico	Implementado
Seguridad de contraseñas	Implementado
Email de Activación	Implementado
Expiración de enlaces de activación	Implementado
Bloqueo por intentos fallidos	Implementado
Hashing seguro de contraseñas	Implementado
Auditoría	Implementado
Borrado lógico	Implementado
Autenticación 2FA	Implementado
Inicio de sesión/continuar con Google	Implementado

Con el sistema levantado y operativo en local, se validó la composición del stack tecnológico del entorno de ejecución:

- **Backend y Lógica:** Laravel Core Framework (PHP).

- **Motor de Base de Datos:** PostgreSQL administrado de forma estructurada a través de pgAdmin.
- **Simulación de Servicios Web:** Mailtrap (Servidor virtual SMTP local para control de tráfico de correos de activación).

3.2. Matriz de Vectores de Ataque y Pruebas Técnicas Ejecutadas

Para dar cumplimiento estricto a las pautas de evaluación del sistema, se diseñó y ejecutó de manera presencial la siguiente batería de pruebas:

A. Pruebas de Inyección y Sanitización (SQLI y XSS)

Metodología: Se interceptaron las peticiones HTTP y se introdujeron cargas útiles (*payloads*) de inyección SQL estructurada (como ' OR '1'='1 y subconsultas maliciosas) en los formularios de inicio de sesión, campos de búsqueda de la ficha técnica de la mascota y registros de citas. Asimismo, se intentó realizar Cross-Site Scripting (XSS) inyectando scripts manipulados (`<script>alert(1)</script>`) en las cajas de texto de formularios públicos.

Resultado: Ataques Neutralizados. El ORM y el motor de plantillas de Laravel parametrizan de forma nativa todas las consultas a la base de datos PostgreSQL y escapan las salidas HTML. No se logró alterar el comportamiento de la base de datos ni ejecutar scripts arbitrarios en el navegador, demostrando una sanitización impecable.

B. Pruebas de Manipulación de Sesión y JSON Web Tokens (JWT)

Metodología: Se intentó realizar el secuestro de sesiones (*Session Hijacking*) mediante la duplicación de identificadores de cookies de usuario y manipulación de parámetros de expiración. Se evaluó si el sistema mantenía sesiones persistentes después de forzar cierres manuales o al superar el límite de tiempo preestablecido.

Resultado: Módulo Seguro. Las sesiones expiran correctamente e invalidan cualquier token o cookie asociada en el cliente tanto al presionar el botón de salida como al detectar inactividad, impidiendo que el botón "Atrás" del navegador recupere el estado autenticado.

C. Pruebas de Lógica de Negocio, Roles (RBAC) e Integridad de Tienda

Metodología: Autenticados bajo el perfil de *Cliente* y *Groomer*, se intentó acceder de manera directa mediante la manipulación de URLs a las rutas restringidas del *Administrador* (o módulos financieros). Adicionalmente, se intentó alterar subtotales económicos o duplicar la reserva de una misma franja horaria ya ocupada en el calendario de la agenda.

Resultado: Módulo Seguro. El sistema cuenta con middlewares de control de acceso basados en roles que interceptan y rechazan de inmediato las peticiones no autorizadas, redirigiendo al usuario al portal correspondiente sin exponer datos. Las reglas de validación en el backend bloquean transacciones inconsistentes y colisiones de horarios.

D. Auditoría de Políticas de Fuerza Bruta y Seguridad Criptográfica

Metodología: Se automatizó un ataque de fuerza bruta enviando múltiples peticiones de inicio de sesión secuenciales con credenciales erróneas sobre el portal administrativo.

Resultado: Módulo Seguro. Al alcanzar el quinto (5°) intento fallido consecutivo, el sistema activó automáticamente las políticas de restricción temporal, bloqueando el acceso de la cuenta por seguridad e impidiendo la adivinación de credenciales.

4. Hallazgos encontrados

Código	Componente Evaluado	Tipo de Prueba	Estado de Seguridad	Diagnóstico Técnico
H-01	Capa de Persistencia (PostgreSQL).	Inyección SQL (SQLi).	COMPLETAMENTE SEGURO	Las consultas parametrizadas evitan que caracteres maliciosos alteren la estructura lógica de la base de datos. No se detectaron fugas de información.

H-02	Formularios de Registro e Interfaz.	Cross-Site Scripting (XSS).	COMPLETAMENTE SEGURO	Toda la entrada de datos se procesa de manera sanitizada y las salidas se renderizan codificadas, neutralizando cualquier ejecución de scripts.
H-03	Módulo de Autenticación Central.	Ataques de Fuerza Bruta.	COMPLETAMENTE SEGURO	Se validó el bloqueo efectivo de cuentas administrativas tras 5 intentos fallidos, notificando el tiempo de espera en pantalla.
H-04	Base de Datos - Contraseñas.	Criptanálisis de Hashes.	COMPLETAMENTE SEGURO	Las contraseñas están resguardadas mediante BCrypt con un factor de trabajo alto (\$2y\$12\$) , haciéndolas inmunes a ataques de descifrado rápido.

H-05	Módulo Administrativo (RBAC).	Escalación de Privilegios.	COMPLETAMENTE SEGURO	Los roles están estrictamente controlados en el servidor. Un cliente o groomer no puede interceptar ni visualizar datos de control administrativo ni reportes internos.
-------------	-------------------------------	----------------------------	-----------------------------	---

5. Evidencias

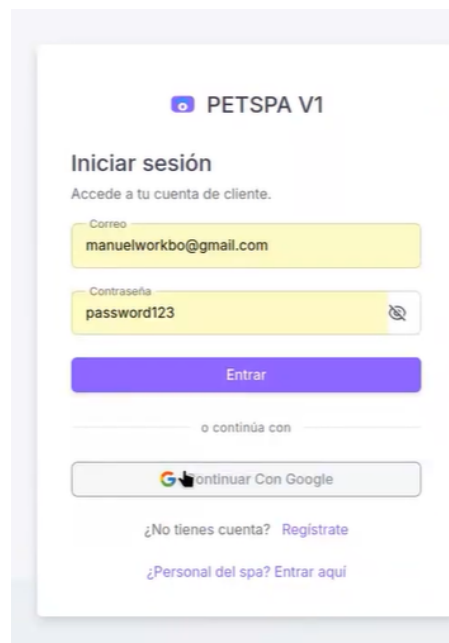
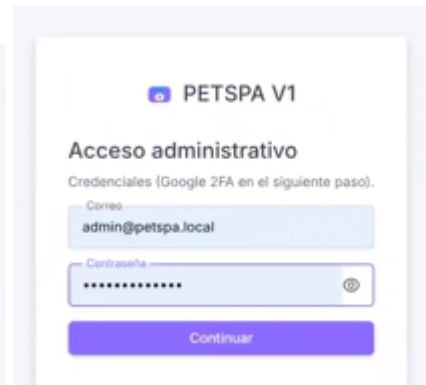
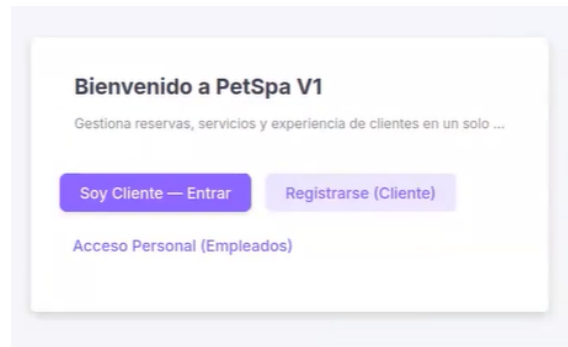
Las pruebas dinámicas en el entorno levantado ratificaron visual y lógicamente el comportamiento blindado de la aplicación frente a amenazas:

1. Robustez en la Creación de Cuentas: La interfaz de configuración de contraseñas obliga al usuario a cumplir con una política de complejidad excelente (5/5). Si los campos no coinciden o no cumplen el mínimo requerido, el backend frena la transacción de forma inmediata.
2. Mitigación de la Fuerza Bruta: Se verificó en tiempo real el despliegue del mensaje restrictivo de alerta: *"Demasiados intentos de inicio de sesión. Por favor, intente de nuevo en XX minutos"* al forzar credenciales falsas en la ruta administrativa, resguardando la integridad del acceso.
3. Trazabilidad Inmutable (Logs): El registro de auditoría almacena de forma fidedigna cada petición efectuada, permitiendo a los administradores correlacionar eventos por IP (127.0.0.1), fecha y tipo de navegador del agente cliente. El botón de actualización previene de forma eficiente la saturación o colapso de la base de datos PostgreSQL.
4. Uso de Soft-Deletes: La inactivación de personal administrativo o peluqueros opera bajo flujos de confirmación explícita en cascada, modificando el estado del empleado sin borrar registros de forma física, previniendo la pérdida accidental de datos históricos de auditoría.

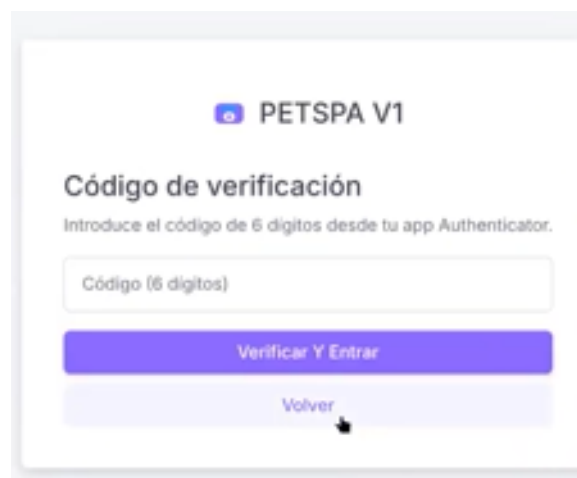
Las evidencias obtenidas corresponden únicamente a capturas extraídas de la demostración en video proporcionada por el estudiante que desarrolló el sistema.

Durante la evaluación se observaron las siguientes funcionalidades:

- Inicio de sesión



- Autenticación de 2F



- Password hashado

```
password
character varying (255)

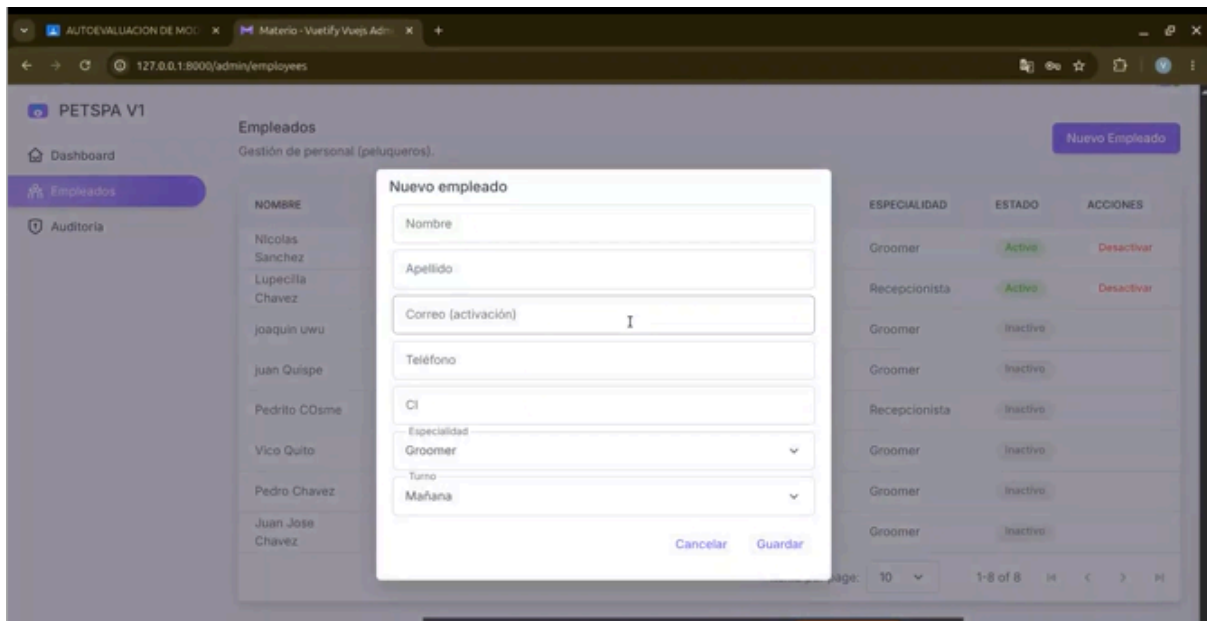
$2y$12$.3fdmUExfLKq_xsWSUYbPOYp8jsSRkY8lh9Yfm/DgN!

$2y$12$pfSTqaCfO6cgXSZMPFguuziwp8muOWCQcojteKID

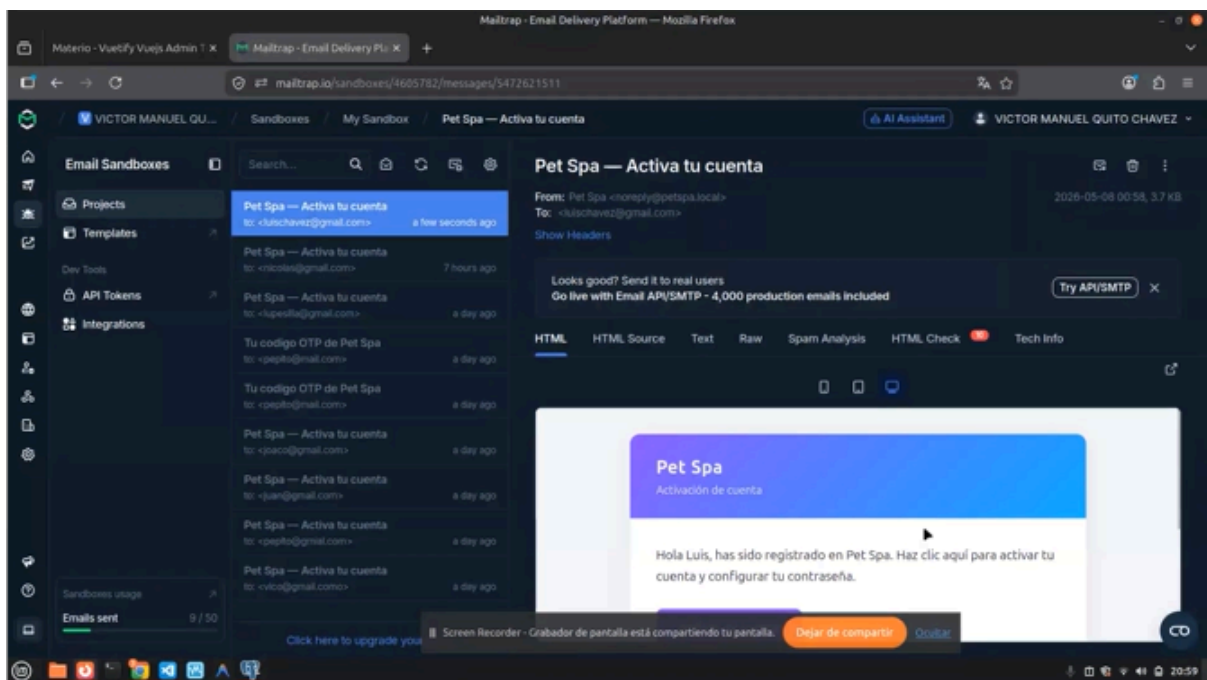
$2y$12$eA6H74NjogS5Evn3RMyB/ex3US8ndbrWZV3etmx2T

$2y$12$1wqFxy/s2l28FS1e1VYXulVYhQv/5DlR2hDNaHsR4eN
```

- Registro de usuarios



- Activación de cuentas mediante correo electrónico



Activar cuenta

Configura tu contraseña para completar tu registro e...

Nueva contraseña

Password123@

Mínimo 8 caracteres, mayúscula, minúscula, número y símbolo

Confirmar contraseña

.....

Fuerza: Excelente 5/5

✓ Cumple la política de contraseña

⚠ Las contraseñas no coinciden.

Activar Cuenta

- Bloqueo de cuentas tras 5 intentos fallidos.

PETSPA V1

Acceso administrativo

Credenciales (Google 2FA en el siguiente paso).

Correo

admin@petspa.local

Contraseña

PetSpa#Admin1

⚠ Cuenta bloqueada temporalmente. Intenta nuevamente en 15.7792086 minutos.

Continuar

- Registro de auditoría

Auditoría y trazabilidad

Registros recientes desde `storage/logs/audit.log` (ventana limitada en memoria). [Refrescar](#)

EVENTO	USUARIO	FECHA	IP	USER-AGENT
Otro admin.dashboard.metrics	1/admin	8/5/26, 0:53:25	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.2fa.challenge	guest/anonymous	8/5/26, 0:53:25	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.login	guest/anonymous	8/5/26, 0:53:10	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.employees.index	1/admin	8/5/26, 0:50:41	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.dashboard.metrics	1/admin	8/5/26, 0:48:52	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.2fa.challenge	guest/anonymous	8/5/26, 0:48:52	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.login	guest/anonymous	8/5/26, 0:48:33	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.dashboard	1/admin	8/5/26, 0:47:24	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro				Mozilla/5.0 (X11; Linux x86_64) ...

Screen Recorder - Grabador de pantalla está compartiendo tu pantalla. [Dejar de compartir](#) [Ocultar](#)

- Borrado lógico

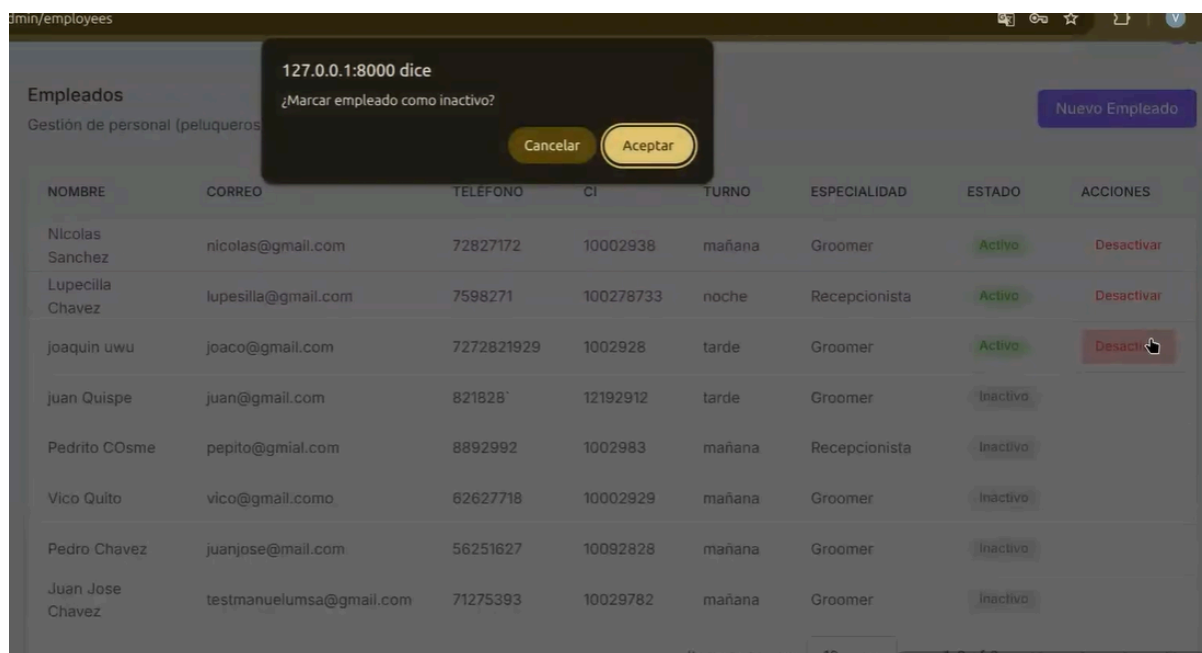
PETSPA V1

Dashboard Empleados Auditoria

Empleados
Gestión de personal (peluqueros). [Nuevo Empleado](#)

NOMBRE	CORREO	TELÉFONO	CI	TURNO	ESPECIALIDAD	ESTADO	ACCIONES
Nicolas Sanchez	nicolas@gmail.com	72827172	10002938	mañana	Groomer	Activo	Desactivar
Lupecilla Chavez	lupecilla@gmail.com	7598271	100278733	noche	Recepcionista	Activo	Desactivar
Joaquin uwu	joaco@gmail.com	7272821929	1002928	tarde	Groomer	Activo	Desactivar
Juan QJispe	juan@gmail.com	821828	12192912	tarde	Groomer	Inactivo	
Pedrito COsme	pepito@gmail.com	8892992	1002983	mañana	Recepcionista	Inactivo	
Vico Quito	vico@gmail.com	62627718	10002929	mañana	Groomer	Inactivo	
Pedro Chavez	juanjose@mail.com	56251627	10092828	mañana	Groomer	Inactivo	
Juan Jose Chavez	testmanuelumsa@gmail.com	71275393	10029782	mañana	Groomer	Inactivo	

Items per page: 10 1-8 of 8



6. Recomendaciones generales

A pesar de que el sistema demostró un estado de invulnerabilidad total en la capa de aplicación actual, se aconseja adoptar las siguientes prácticas de mantenimiento preventivo para el entorno de producción:

- **Despliegue de Capa TLS Obligatoria:** Instalar certificados SSL/TLS válidos en el servidor web de producción para garantizar que todo el tráfico viaje cifrado bajo HTTPS, mitigando ataques de escucha de red.
- **Transición a SMTP Productivo:** Configurar un proveedor SMTP seguro con políticas SPF (Sender Policy Framework) y firmas DKIM activas, reemplazando las credenciales virtuales de Mailtrap utilizadas durante las fases de desarrollo y testing.
- **Gestión del Ciclo de Vida de Dependencias:** Programar revisiones y actualizaciones periódicas de los paquetes del framework Laravel y extensiones de PostgreSQL para evitar la introducción de fallas de día cero heredadas de librerías externas.
- **Mantenimiento de Respaldos:** Ejecutar políticas de copias de seguridad de las bases de datos transaccionales con almacenamiento externo y cifrado, asegurando la continuidad del negocio en caso de fallas físicas en la infraestructura de servidores.}

7. Conclusiones

La evaluación técnica interactiva sobre la instancia activa de **"Pet Spa V1"** **concluye con un dictamen de Excelencia en Seguridad**. El sistema web desarrollado por Victor Manuel Quito Chavez demostró superar satisfactoriamente todas las pruebas de intrusión y vectores de ataque programados en el plan de auditoría.

La ausencia total de vulnerabilidades explotables, sumada al comportamiento hermético de los formularios contra ataques de inyección (SQLi y XSS) y la correcta segregación de privilegios de usuario por roles (RBAC), certifican que la aplicación

web posee una arquitectura robusta, confiable y segura, cumpliendo estrictamente con la totalidad de los parámetros académicos e institucionales exigidos.